

Área de Conocimiento de Tecnología de la Información y Comunicación

Auditoria de Sistemas

Redacción de hallazgos de la auditoria de redes en el SILAIS Sede Masaya

Elaborado por:

Br. Gerson Antonio
Valdivia

Br. Haxell Antonio
Trejos Rodríguez

Br. Alison Michelle
Navarro Goussen

Br. Stephanie Lucía
Mora Chávez

Br. Arleth del Rosario
Velásquez Gómez

Docente:

Msc. Leonel Antonio Martínez Zuniga

09 de mayo, 2026
Managua, Nicaragua

HALLAZGOS

HALLAZGOS DE INFRAESTRUCTURA DE HARDWARE DE RED

HALLAZGO No. H-RED-INFRA-01

SILAIS – SEDE MASAYA			REF: H-RED-INFRA-01		
HALLAZGOS DE LA AUDITORIA			H1		
PROCESO AUDITADO	Gestión operativa de la red – Mantenimiento de infraestructura		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	COBIT DSS01, ISO 27001 A.11.2.4				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones		
DESCRIPCIÓN DEL HALLAZGO					
No existe un programa documentado de mantenimiento preventivo para los equipos de comunicación (switches y UPS). Las actividades de limpieza, verificación de ventiladores y comprobación de baterías de UPS no se realizan de manera programada. La supervisión del estado operativo de estos equipos es reactiva, atendiendo únicamente los fallos que son reportados por los usuarios.					
CAUSAS					
• Inexistencia de un responsable de red designado formalmente. • Falta de políticas y procedimientos documentados para la gestión de operaciones de red. • Cultura organizacional reactiva, enfocada en resolver incidencias en lugar de prevenirlas.					
EVIDENCIA					
• Respuesta negativa a la solicitud de cronogramas o bitácoras de mantenimiento preventivo. • Checklist Módulo I, criterio F-05: Área con ventilación y limpieza adecuada. Respuesta: NO. • Entrevistas con personal de Planificación.					
IMPACTO					
• Degradación progresiva de los equipos de comunicación. • Reducción significativa de la vida útil de los switches y UPS. • Mayor probabilidad de fallos inesperados durante picos de operación.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
R-RED-008: Fallo prematuro por falta de mantenimiento preventivo	Alto (3)	Alta (4)	Alto (12)		
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
RECOMENDACIONES					
1. Corto plazo (30-60 días): Elaborar un programa de mantenimiento preventivo semestral que incluya limpieza interna y externa de switches, verificación del funcionamiento de ventiladores y comprobación de la autonomía de las baterías de las UPS. 2. Corto plazo: Asignar al responsable de red la ejecución y documentación de estas tareas en bitácoras formales.					

HALLAZGO No. H-RED-INFRA-02

SILAIS – SEDE MASAYA		REF: H-RED-INFRA-02		
HALLAZGOS DE LA AUDITORIA		H2		
PROCESO AUDITADO	Gestión operativa de activos de red – Cableado estructurado	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	ANSI/TIA-568-C, ANSI/TIA-569-C, ISO 27001 A.11.2, COBIT DSS01			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones	
DESCRIPCIÓN DEL HALLAZGO				
La infraestructura de cableado estructurado presenta serias deficiencias. En diez de las catorce áreas funcionales el cableado UTP se encuentra expuesto, sin la protección de canaletas plásticas. No se utilizan patch panels ni patch cords; el cableado horizontal sólido se conecta directamente a los puertos de los switches. Tampoco existen rosetas de pared en los puntos de trabajo, quedando los conectores RJ45 colgando directamente, sometidos a tensión constante.				
CAUSAS				
• Instalación inicial de la red sin la supervisión de un profesional certificado en estándares de cableado estructurado. • Falta de presupuesto para completar la instalación de canaletas y la adquisición de patch panels y rosetas. • Desconocimiento de los estándares ANSI/TIA/EIA por parte del personal que ha manipulado la red.				
EVIDENCIA				
• Fotografías del cableado expuesto, torceduras y conectores RJ45 colgando. • Checklist Módulo II (Cableado y Canalización) y Módulo III (Área de Trabajo), con múltiples criterios evaluados negativamente.				
IMPACTO				
• Alta probabilidad de rotura de conductores y fallos intermitentes de conectividad. • Daño a los puertos de los switches por la tensión del cable sólido horizontal. • Dificultad para realizar tareas de mantenimiento y una imagen de desorden generalizada.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
R-RED-009: Interrupción de conectividad por daño al cableado expuesto	Medio (2)	Alta (4)	Alto (8)	
RECOMENDACIONES				
1. Corto plazo (30-60 días): Completar la instalación de canaletas plásticas en las diez áreas que carecen de protección. 2. Corto plazo: Instalar patch panels de 24 puertos en ambos nodos y rosetas de pared en todas las áreas de trabajo. 3. Corto plazo: Adquirir y utilizar patch cords flexibles de fábrica para la conexión final.				

HALLAZGO No. H-RED-INFRA-03

SILAIS – SEDE MASAYA		REF: H-RED-INFRA-03		
HALLAZGOS DE LA AUDITORIA		H3		
PROCESO AUDITADO	Gestión operativa de la red – Rendimiento y capacidad	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	ISO 27001 A.17.2.1, COBIT DSS01, Normativa SISNIVEN			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones	
DESCRIPCIÓN DEL HALLAZGO				
Mediante la utilización del Analizador de Redes por Hardware NetAlly EtherScope nXG, se verificó que la velocidad de negociación de todos los enlaces de la red LAN es de 100 Mbps. Esta limitación es impuesta por los switches Fast Ethernet no administrables, los cuales son la causa del estrangulamiento operativo. Las estaciones de trabajo, equipadas con tarjetas de red Gigabit, operan a un 10% de su capacidad, lo que restringe el rendimiento de las aplicaciones críticas, incluyendo la transmisión de datos del SISNIVEN al MINSA Central.				
CAUSAS				
• Obsolescencia tecnológica de los switches Fast Ethernet no administrables. • Falta de un plan de renovación tecnológica de la infraestructura de red. • Ausencia de monitoreo de rendimiento que hubiera permitido detectar el cuello de botella de forma proactiva.				
EVIDENCIA				
• Reporte de pruebas de velocidad de enlace generado por el Analizador NetAlly EtherScope nXG, confirmando la negociación a 100 Mbps en todos los puertos. • Fichas técnicas de los switches que indican una velocidad máxima de Fast Ethernet. • Entrevistas con usuarios de áreas críticas que reportan lentitud en aplicaciones.				
IMPACTO				
• Limitación del rendimiento de todas las aplicaciones de red, ralentizando la transferencia de datos epidemiológicos y administrativos. • Imposibilidad de implementar servicios que requieran un mayor ancho de banda. • Desaprovechamiento de la inversión en estaciones de trabajo con capacidad Gigabit.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado		Impacto	Probabilidad	Nivel de Riesgo
Proceso DSS01 no implementado: Estrangulamiento crónico del rendimiento de la red		Medio (2)	Muy Alta (5)	Alto (10)
RECOMENDACIONES				
1. Prioritaria (30-60 días): Reemplazar los switches Fast Ethernet por switches Gigabit administrables para eliminar el cuello de botella. 2. Corto plazo: Implementar un sistema de monitoreo de ancho de banda para establecer una línea base de rendimiento y verificar la mejora tras el reemplazo.				

HALLAZGO No. H-RED-INFRA-04

SILAIS – SEDE MASAYA			REF: H-RED-INFRA-04		
HALLAZGOS DE LA AUDITORIA			H4		
PROCESO AUDITADO	Gestión operativa de la red – Condiciones ambientales		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	ANSI/TIA-569-C, ISO 27001 A.11.1.4, COBIT DSS01				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones		
DESCRIPCIÓN DEL HALLAZGO					
La monitorización ambiental realizada con sensores dedicados NetBotz durante un período de 48 horas reveló condiciones adversas en las áreas de comunicaciones. Se registraron temperaturas pico superiores a los 34°C y niveles de humedad relativa que alcanzaron el 88%, excediendo los rangos operativos recomendados para los equipos de red. Adicionalmente, la medición de calidad de energía con el analizador Fluke 430 Series II mostró la presencia de armónicos y fluctuaciones de voltaje que exceden los límites seguros, representando un riesgo para las fuentes de poder de los switches y las UPS.					
CAUSAS					
- Falta de un sistema de climatización dedicado en las áreas de comunicaciones. - Inexistencia de un sistema de monitoreo ambiental continuo. - Conexión de los equipos a la red eléctrica general, sin sistemas de filtrado o acondicionamiento de energía.					
EVIDENCIA					
- Reporte de tendencias de temperatura y humedad generado por los sensores NetBotz, mostrando las excursiones fuera de los rangos aceptables. - Mediciones del Analizador de Calidad de Energía Fluke 430 Series II que documentan los armónicos y fluctuaciones de voltaje. - Fotografías de las áreas de switches evidenciando la falta de climatización.					
IMPACTO					
- Aceleración de la degradación de los componentes electrónicos de los switches. - Aumento significativo del riesgo de fallo prematuro por sobrecalentamiento o estrés eléctrico. - Posible invalidación de garantías de los fabricantes por operar fuera de las condiciones especificadas.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado		Impacto	Probabilidad	Nivel de Riesgo	
R-RED-008: Fallo prematuro de switches por condiciones ambientales y eléctricas adversas		Alto (3)	Alta (4)	Alto (12)	
RECOMENDACIONES					
- Corto plazo (30-60 días): Instalar un sistema de climatización (aire acondicionado) dedicado en las áreas de Dirección y Varios 1 para controlar la temperatura y la humedad. - Corto plazo: Implementar un sistema de monitoreo ambiental continuo con alertas. - Mediano plazo: Evaluar la instalación de un sistema de acondicionamiento de energía para proteger los equipos de red de las fluctuaciones de la red eléctrica.					

I. HALLAZGOS DE ARQUITECTURA LÓGICA Y SEGURIDAD DE RED

HALLAZGO No. H-RED-LOG-01

SILAIS – SEDE MASAYA		REF: H-RED-LOG-01		
HALLAZGOS DE LA AUDITORIA		H5		
PROCESO AUDITADO	Seguridad de las comunicaciones – Segmentación de red	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	ISO 27001 A.13.1.1, COBIT DSS05, Ley 921			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad	
DESCRIPCIÓN DEL HALLAZGO				
La red LAN del SILAIS – Sede Masaya opera bajo una topología de red plana sin segmentación VLAN. Todas las áreas funcionales, incluyendo áreas críticas que manejan datos sensibles (Epidemiología, Banco Biológico), comparten el mismo dominio de broadcast con áreas administrativas y de uso compartido. Los switches Fast Ethernet, al no ser administrables, carecen de la capacidad técnica para implementar VLANs o listas de control de acceso.				
CAUSAS				
• Obsolescencia tecnológica de los switches Fast Ethernet, que no soportan la funcionalidad de segmentación lógica. • Falta de un diseño de arquitectura de red que contemple la separación por niveles de sensibilidad de datos. • Inexistencia de políticas de seguridad de la información que exijan la segmentación como control.				
EVIDENCIA				
• Pruebas de conectividad (comando ping) exitosas entre equipos de "Varios 1" y equipos de "Epidemiología" y "Banco Biológico", confirmando la ausencia de restricciones. • Checklist Módulo IV (Arquitectura Lógica), criterio S-02: ¿Están configuradas Redes Virtuales (VLANs)? Respuesta: NO.				
IMPACTO				
• Movimiento lateral sin restricciones para malware; un ataque de ransomware originado en un área de uso compartido puede cifrar datos en áreas críticas. • Acceso no autorizado a datos sensibles de pacientes desde cualquier punto de la red. • Incumplimiento de la Ley 921 de Protección de Datos Personales.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
R-RED-002: Cifrado de datos SISNIVEN por ransomware propagado en red plana	Catastrófico (5)	Alta (4)	Extremo (20)	
RECOMENDACIONES				
1. Prioritaria (30-60 días): Reemplazar los switches Fast Ethernet por switches Gigabit administrables con soporte para VLANs (802.1Q). 2. Al momento del reemplazo: Configurar la segmentación VLAN para aislar el tráfico de las áreas críticas (Epidemiología, Banco Biológico) del resto de la red. 3. Implementar Listas de Control de Acceso (ACLs) entre las VLANs para reforzar la seguridad.				

HALLAZGO No. H-RED-LOG-03

SILAIS – SEDE MASAYA			REF: H-RED-LOG-03		
HALLAZGOS DE LA AUDITORIA			H6		
PROCESO AUDITADO	Seguridad de la red – Gestión de conexiones externas		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	ISO 27001 A.13.1.1, COBIT DSS05				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad		
DESCRIPCIÓN DEL HALLAZGO					
Se identificaron conexiones privadas a Internet operando en las áreas de Sindicato, SNC y Transporte, las cuales funcionan de manera independiente a la red corporativa del SILAIS. Estas conexiones no cuentan con autorización formal documentada, no están integradas en la red corporativa mediante una VLAN de invitados, y no se les aplica ningún tipo de monitoreo de tráfico o control de seguridad (filtrado de contenido, prevención de intrusiones).					
CAUSAS					
• Inexistencia de una política institucional que regule la instalación y el uso de conexiones a Internet alternativas. • Falta de un administrador de red que unifique y controle todos los puntos de acceso a Internet. • Percepción de estas áreas como "independientes" desde el punto de vista administrativo.					
EVIDENCIA					
• Entrevistas con los responsables de Sindicato, SNC y Transporte, quienes confirmaron la existencia y el pago independiente de estas conexiones. • Inspección física de los routers/módems de conexión privada en las áreas mencionadas. • Documentación inexistente sobre la autorización de estas conexiones por parte de la Dirección.					
IMPACTO					
• Creación de puntos de fuga de información no controlados hacia el exterior. • Bypass de todos los controles de seguridad corporativos, exponiendo al SILAIS a ataques externos sin posibilidad de detección. • Imposibilidad de auditar el tráfico de estas conexiones para cumplir con la Ley 921 de Protección de Datos Personales.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
R-RED-010: Fuga de información institucional a través de conexiones no monitoreadas	Crítico (4)	Baja (2)	Alto (8)		
RECOMENDACIONES					
1. Corto plazo (30-60 días): Evaluar la integración de estas conexiones a la red corporativa. La mejor práctica es unificarlas bajo un único proveedor de servicios y segmentarlas en una VLAN de invitados con acceso solo a Internet y sin visibilidad de la red interna. 2. Mientras no se integren: Formalizar su existencia mediante una autorización de la Dirección y aplicarles medidas de seguridad básicas como cambio de contraseñas por defecto y filtrado de contenido.					

HALLAZGO No. H-RED-LOG-03

SILAIS – SEDE MASAYA			REF: H-RED-LOG-02		
HALLAZGOS DE LA AUDITORIA			H7		
PROCESO AUDITADO	Seguridad de la red inalámbrica		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	ISO 27001 A.11.2.2, COBIT DSS05				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad		
DESCRIPCIÓN DEL HALLAZGO					
Catorce equipos en áreas funcionales críticas (Estadística, Contabilidad, Insumos Médicos, Enfermería y RRHH) dependen exclusivamente de conectividad WiFi para sus operaciones, sin disponer de puntos de red cableada como respaldo. Adicionalmente, se desconoce la configuración de seguridad de la red inalámbrica, ya que no existe documentación sobre el protocolo de cifrado (WPA2, WPA3), el mecanismo de autenticación utilizado ni la intensidad de la señal en los puntos de trabajo.					
CAUSAS					
- Planificación de la infraestructura de conectividad sin considerar la redundancia en áreas críticas. - Instalación de puntos de acceso WiFi sin el tendido paralelo de cableado UTP. - Ausencia de una gestión proactiva de la red que evalúe y documente las configuraciones de seguridad.					
EVIDENCIA					
- Tabla de distribución de conectividad por área funcional, que documenta la dependencia WiFi. - Checklist Módulo III, criterio E-06: ¿Las áreas críticas cuentan con puntos de red cableada como respaldo? Respuesta: NO.					
IMPACTO					
- Interrupción de la conectividad en procesos críticos de consolidación de datos estadísticos y gestión de inventario farmacéutico ante una caída de la señal WiFi. - Riesgo de interceptación de tráfico sensible (Man-in-the-Middle) si el protocolo de cifrado es débil o inexistente.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
R-RED-004: Interceptación de credenciales y datos vía WiFi	Crítico (4)	Media-Alta (4)	Extremo (16)		
R-RED-006: Exposición de datos por WiFi con cifrado débil	Alto (3)	Media (3)	Alto (9)		
RECOMENDACIONES					
3. Corto plazo (30-60 días): Instalar puntos de red cableada como conexión principal en las áreas críticas, dejando la conectividad WiFi como respaldo. 4. Inmediata (0-15 días): Verificar y documentar el protocolo de cifrado y autenticación de los puntos de acceso; si es inferior a WPA2, planificar su actualización a WPA3.					

III. HALLAZGOS DE GESTIÓN Y GOBERNANZA DE LA RED

HALLAZGO No. H-RED-GOB-01

SILAIS – SEDE MASAYA		H-RED-GOB-01		
HALLAZGOS DE LA AUDITORIA		H8		
PROCESO AUDITADO	Gestión de Incidentes de Red		PAGINA	
			1	DE 1
RESPONSABLE				
CRITERIO	ISO 27001 A.16.1, COBIT DSS02			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS02 – Gestión de Solicitudes e Incidentes	
DESCRIPCIÓN DEL HALLAZGO				
No existe un procedimiento formal ni una herramienta (como un sistema de tickets) para el registro, seguimiento y resolución de incidentes de red. Las fallas de conectividad se reportan de manera verbal o informal a personas que, sin designación oficial, intentan resolverlas. No se genera documentación que permita analizar la recurrencia de los problemas.				
CAUSAS				
- Inexistencia de un administrador de red responsable de la gestión de incidentes. - Falta de implementación de un sistema de mesa de ayuda básico. - Cultura organizacional reactiva que no prioriza el registro de eventos.				
EVIDENCIA				
- Entrevistas con el personal de las áreas de Epidemiología, Estadística y Planificación, quienes confirmaron el procedimiento informal. - Checklist de gestión de red, criterio DSS02: ¿Existe un registro formal de incidentes de red? Respuesta: NO.				
IMPACTO				
- Tiempos de respuesta y resolución de fallos excesivos y no controlados. - Imposibilidad de identificar problemas recurrentes o medir la calidad del servicio de red. - Sensación de desamparo en los usuarios al no tener un canal claro de reporte.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
Proceso DSS02 no implementado: Respuesta ineficiente a incidentes	Alto (3)	Muy Alta (5)	Alto (15)	
RECOMENDACIONES				
- Corto plazo: Designar al responsable de red como punto único de contacto para el reporte de incidentes. - Corto plazo: Implementar un sistema de tickets simple (puede ser una hoja de cálculo compartida o una herramienta gratuita) para registrar, dar seguimiento y documentar la resolución de cada incidente.				

HALLAZGO No. H-RED-GOB-02

SILAIS – SEDE MASAYA			H-RED-GOB-02		
HALLAZGOS DE LA AUDITORIA			H9		
PROCESO AUDITADO	Gestión de la Continuidad de la Red		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	COBIT DSS04, ISO 27001 A.17.2				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS04 – Gestión de la Continuidad		
DESCRIPCIÓN DEL HALLAZGO					
El SILAIS – Sede Masaya no cuenta con un Plan de Continuidad de Negocio o Recuperación ante Desastres (BCP/DRP) para la infraestructura de red. No existen procedimientos documentados que describan las acciones a tomar para restablecer la conectividad en caso de un fallo catastrófico del switch principal, la pérdida del enlace con el MINSA Central o cualquier otro incidente que paralice las comunicaciones.					
CAUSAS					
• Inexistencia de un responsable de TI que impulse la elaboración del plan. • Falta de conciencia sobre la dependencia crítica de la institución en la conectividad de red para la operación del SISNIVEN. • Ausencia de una política institucional de continuidad del negocio.					
EVIDENCIA					
• Inexistencia de un responsable de TI que impulse la elaboración del plan. • Falta de conciencia sobre la dependencia crítica de la institución en la conectividad de red para la operación del SISNIVEN. • Ausencia de una política institucional de continuidad del negocio.					
IMPACTO					
• Inexistencia de un responsable de TI que impulse la elaboración del plan. • Falta de conciencia sobre la dependencia crítica de la institución en la conectividad de red para la operación del SISNIVEN. • Ausencia de una política institucional de continuidad del negocio.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
R-RED-001: Colapso total de la LAN por fallo catastrófico	Catastrófico (5)	Alta (4)	Extremo (20)		
RECOMENDACIONES					
1. Inmediato (0-15 días): Convocar a un grupo de trabajo multidisciplinario para la elaboración del Plan de Continuidad y Recuperación ante Desastres de la red. 2. Corto plazo (30-60 días): Documentar el plan, definiendo roles, procedimientos de recuperación, RTOs (Recovery Time Objectives) y un listado de contactos de emergencia. Realizar una prueba de escritorio del plan.					

HALLAZGO No. H-RED-GOB-03

SILAIS – SEDE MASAYA		H-RED-GOB-03		
HALLAZGOS DE LA AUDITORIA		H10		
PROCESO AUDITADO	Gestión de Problemas de Red		PAGINA	
			1	DE 1
RESPONSABLE				
CRITERIO	ISO 27001 A.16.1, COBIT DSS03			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS03 – Gestión de Problemas	
DESCRIPCIÓN DEL HALLAZGO				
No se evidencia la existencia de un proceso de Gestión de Problemas. Los incidentes de red (como caídas de WiFi o lentitud) se resuelven de manera reactiva, pero no se realiza un análisis estructurado de la causa raíz para identificar y erradicar los problemas subyacentes. Las soluciones aplicadas son, por lo general, temporales o se enfocan en restaurar el servicio, sin documentar acciones para prevenir la recurrencia.				
CAUSAS				
• Inexistencia de personal formalmente designado para la gestión de la red en todos sus niveles (no solo reactivo). • Confusión entre los procesos de Gestión de Incidentes (DSS02) y Gestión de Problemas (DSS03). • Falta de una metodología para el análisis de causa raíz (Diagrama de Ishikawa, 5 Porqués).				
EVIDENCIA				
• Entrevistas con el personal que eventualmente brinda soporte. • Ausencia de documentación que demuestre análisis de fallos recurrentes (ej. reportes de causa raíz). • Checklist de gestión de red, criterio DSS03: ¿Se realiza análisis de problemas recurrentes? Respuesta: NO.				
IMPACTO				
• Fallos recurrentes que afectan la productividad y la continuidad operativa. • Inversión de tiempo y recursos en "apagar incendios" en lugar de resolver problemas de fondo. • Prolongación de los tiempos de indisponibilidad de la red al no atacar las causas raíz.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado		Impacto	Probabilidad	Nivel de Riesgo
Proceso DSS03 no implementado: Cronificación de fallos de red por falta de solución definitiva		Alto (3)	Muy Alta (5)	Alto (15)
RECOMENDACIONES				
1. Corto plazo: Instituir formalmente la práctica de realizar un análisis de causa raíz para todo incidente de red que se repita o que tenga un impacto mayor. 2. Corto plazo: El responsable de la red deberá crear y mantener un registro de problemas (KDB, Known Error Database) que documente las soluciones definitivas a fallos recurrentes.				

HALLAZGO No. H-RED-GOB-04

SILAIS – SEDE MASAYA		H-RED-GOB-04		
HALLAZGOS DE LA AUDITORIA		H11		
PROCESO AUDITADO	Gestión de Riesgos de la Red		PAGINA	
			1	DE 1
RESPONSABLE				
CRITERIO	COBIT DSS03, DSS05, ISO 27001 A.13.1, A.16.1			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS03 – Gestión de Problemas / DSS05 – Gestión de Servicios de Seguridad	
DESCRIPCIÓN DEL HALLAZGO				
El SILAIS – Sede Masaya no cuenta con un proceso formal de gestión de riesgos de la infraestructura de red. No se ha establecido un marco para la identificación, análisis, evaluación y tratamiento de los riesgos técnicos (ej. obsolescencia de switches, topología de red plana, dependencia WiFi) ni de los riesgos de seguridad de la información. Los riesgos identificados en la presente auditoría no forman parte de un registro oficial ni son monitoreados periódicamente por la institución.				
CAUSAS				
- Ausencia de un responsable de TI o de un comité de seguridad que impulse la gestión de riesgos. - Falta de conocimiento sobre metodologías de análisis de riesgos como ISO 27005. - La gestión de la red ha estado enfocada en la operación diaria, sin una visión estratégica de gobierno.				
EVIDENCIA				
- Respuesta negativa a la solicitud de documentación de un registro o matriz de riesgos de TI. - Entrevistas con la Dirección y Planificación, confirmando la inexistencia del proceso. - Los riesgos presentados en el diagnóstico (R-RED-001 a R-RED-017) fueron identificados por el equipo auditor, no por la institución.				
IMPACTO				
- La Alta Dirección carece de visibilidad sobre los riesgos tecnológicos que amenazan la continuidad del SISNIVEN. - Las decisiones de inversión en TI no se basan en un perfil de riesgo documentado. - Los riesgos de nivel "Extremo" permanecen sin un plan de tratamiento formal.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
Riesgo Global: Todos los riesgos identificados, al no ser gestionados formalmente, tienen una mayor probabilidad de materializarse	Catastrófico (5)	Alta (4)	Extremo (20)	
RECOMENDACIONES				
- Inmediato (0-15 días): Adoptar formalmente la Matriz de Riesgos de Red generada en esta auditoría como el punto de partida del registro de riesgos. - Corto plazo (30-60 días): Asignar al futuro responsable de TI la tarea de facilitar e implementar un proceso de gestión de riesgos (alineado a ISO 27005). Este proceso debe establecer la metodología, las responsabilidades y la periodicidad de la revisión de riesgos.				